

Ethical hacking Breaking in — with permission — so the criminals can't.

Ethical hacking means using the same tools and techniques a criminal would — but with the owner's written permission, and the goal of fixing weaknesses instead of exploiting them.

What this key knowledge covers

This summary distils everything you need for **KK12 — Ethical hacking Breaking in — with permission — so the criminals can't.** in Cyber Security. Work through the explanations, then use the worked good-vs-weak answers to see exactly how marks are won and lost. Tick off the revision checklist at the end before a SAC or exam.

Study summary

What ethical hacking actually is

Ethical hacking means using the *same* tools and techniques a criminal would — but with the owner's written permission, and the goal of **fixing** weaknesses instead of exploiting them.

Ethical hacking is the **authorised**, legal practice of deliberately attempting to penetrate a network or system on behalf of its owner, in order to **identify vulnerabilities and weaknesses** before a malicious attacker can find and exploit them. The tester is also called a **penetration tester** or **white-hat hacker**, and the engagement is often called a **penetration test** (pen test).

Strip away the drama and ethical hacking has three parts that *must* all be present:

The owner has given **written permission** and agreed exactly what may be tested (the *scope*).
No permission = it's just a crime.

Scanning, probing, password attacks, exploiting bugs — identical to what a real attacker does.
The skills are neutral; intent isn't.

The aim is to **report** what was found so it can be patched — never to steal, damage or sell.
Findings go to the owner, not the dark web.

You hire a locksmith to break into your own house. They jimmy the back window, pick the front lock, and hand you a list: "your laundry window doesn't latch, your deadbolt is a cheap one."
Same actions as a burglar — but you *asked* them, they *told* you, and now you can fix it. A burglar does the same break-in and leaves with your TV. **The permission slip is the whole difference.**

White, grey & black hats

The "hat" colours come from old Western films — heroes wore white, villains wore black. In security they describe a hacker's **authorisation and intent**, not their skill.

Has explicit permission and a defined scope. Finds weaknesses and **reports them to the owner**. This is the ethical hacker / penetration tester. Fully legal.

Pokes at systems they **weren't** authorised to test, then tells the owner instead of exploiting. Good intentions, but **still illegal** — they crossed a line they had no right to cross.

No permission and harmful intent — steals data, deploys ransomware, sells access. The criminal attacker ethical hacking is designed to stay ahead of.

The role: find the holes before the criminals do

The study design is precise: ethical hacking's role is **identifying vulnerabilities and weaknesses in networks**. It is the network's fire drill — a controlled attack that exposes problems while it's still safe to fix them.

Proactive, not reactive

Most security is *reactive* — you patch the hole *after* the breach, once data is already gone and the news has the story. Ethical hacking flips this: it's proactive. You discover the weakness on *your* terms, in a controlled test, before a real attacker stumbles onto it.

What a pen test actually checks

A good engagement doesn't just rattle the firewall. It probes the whole network for weaknesses across **technology, configuration and people**:

Old versions of an operating system, server or app with known, published holes attackers already have tools for.

A firewall port left open, default settings never changed, a database reachable from the internet by mistake.

Guessable, reused or never-changed passwords; missing multi-factor authentication on staff accounts.

Whether staff fall for a phishing email or hand over access — often tested with the owner's consent too.

If Clutch launches "Test-Ready Mode" and a black hat finds an **open database port** first, 40,000 teenagers' licence photos end up for sale and the Privacy Act's Notifiable Data Breaches scheme kicks in. If a **white hat** finds the same open port two weeks earlier, it's a one-line fix and a quiet launch. Same hole — wildly different week.

A school doesn't wait for a real fire to discover the back exit is chained shut. It runs a drill — a controlled, fake emergency — to find the blocked door *while everyone's safe*. A pen test is a fire drill for the network: a fake attack that reveals the real problems before they matter.

The White-Hat Lab

Here is Clutch's network. Run the **same** intrusion two ways. As a white hat (authorised) you stay inside the scope, find the holes and the team patches them. As a black hat (no permission) the identical attack ends with data walking out the door. **Watch what changes — and what**

doesn't.

The packet path, the discovered holes and the techniques are *identical* in both modes. Only two things differ: whether there's a **scope boundary** the tester respects, and whether the ending is "**patched**" or "**breached**." That's the whole lesson of this dot point in one animation.

Inside a penetration test

A pen test isn't random button-mashing. It follows recognised stages — the same ones a real attacker would, run in a disciplined order. Tap each phase to see what happens, and what it means for Clutch.

Authorised — or a crime?

In Australia, accessing a computer system without permission is an offence (under the Commonwealth *Criminal Code* / cybercrime law). The exact same keystrokes are either a paid professional service or a criminal act — and the only thing that decides it is **authorisation**.

The test that decides everything: did the owner give prior, written permission, and did the tester stay within the agreed scope ? If yes to both → ethical hacking. If no to either → unauthorised access, a crime — no matter how good the intentions were.

Bug bounties — ethical hacking, crowdsourced

Big companies (and a few brave start-ups like Clutch) run **bug bounty programs**: a public invitation that says "here are the rules — find a flaw within them and we'll pay you." That published invitation *is* the authorisation. It turns thousands of would-be grey hats into legal white hats, because everyone is now testing with permission.

What ethical hacking can't do

A strong answer doesn't treat pen testing as magic. To reach the top band you have to show you understand its **limitations** as well as its value — that's what "evaluate" questions are fishing for.

A pen test shows weaknesses **on the day it ran**. New code, new staff or a new bug next month can reopen the door. Security has to be ongoing.

The tester hands over a report. If the organisation never acts on it (*remediation*), nothing is safer. The list alone protects no one.

A narrow scope can miss the very system that gets breached. Anything ruled "out of scope" simply isn't checked.

You're handing a skilled hacker the keys. A poor or dishonest tester is a serious risk — reputable, vetted professionals matter.

Aggressive testing can crash live services or corrupt data, which is exactly why scope and timing are agreed in advance.

It's one layer. It works alongside firewalls , MFA, patching, backups and staff training — never instead of them.

Clutch's pen test finds four holes and the team patches three before launch — but skips "low priority" #4 to save time. Six weeks later that exact flaw is exploited. The test did its job: it **found** the hole. The breach happened because Clutch didn't finish the **remediation**. Finding

isn't fixing.

Named exam traps

These are the specific mistakes that quietly cost students marks on this dot point. Learn the trap, dodge the loss.

Writing trainer

VCE marks reward structure. Decode the command word first, then use **P•E•L** — Point, Explain, Link — to make sure every answer earns its marks.

VCE-style exam questions

Five questions, **20 marks** total, building from *Define* to *Evaluate*. Try each on paper first. Then reveal a weak answer, a strong answer and the marking guide — and self-mark into the score dock.

"Ethical hacking is when someone hacks into a computer to test it and find problems."

Why it loses marks: no mention of *authorisation/permission* (the defining feature) and no mention of the *purpose* (identifying vulnerabilities). It describes any hacker.

"Ethical hacking is the **authorised**, legal attempt to penetrate a network or system on behalf of its owner, in order to **identify vulnerabilities and weaknesses** so they can be fixed before a malicious attacker exploits them."

A definition missing the word "authorised" caps at 1 mark, however well-written.

"Because they are a grey hat, not a white hat. Grey hats are in between so it's not really ethical."

Why it loses marks: circular — it labels the hat instead of *explaining*. No reference to authorisation, and no link to the act being illegal.

"Ethical hacking requires the owner's **prior authorisation** and an agreed scope. The grey hat accessed Clutch's system **without permission**, which means the access itself was **unauthorised — a criminal offence** — regardless of their good intent. Warning Clutch afterwards is responsible, but it doesn't retrospectively make the access legal, so it can't be classed as ethical hacking."

Ethical hacking — the whole dot point

- **Authorised**, legal attempt to penetrate a network
- On behalf of the **owner**, within an agreed **scope**
- Aka **white hat** / **penetration tester**
- **Identify** vulnerabilities & weaknesses
- **Proactive** — before attackers find them
- Checks software, config, passwords & people
- **White** = authorised + reports = ethical
- **Grey** = no permission + reports = still illegal
- **Black** = no permission + malicious = criminal
- 1 Scope & authorise (the legal step)
- 2 Recon · 3 Scan · 4 Exploit

- 5 Report & remediate
- Snapshot in time — repeat it
- **Finds, doesn't fix** — needs remediation
- Scope-limited · relies on trust · one layer only
- Always say **authorised** / **permission**
- Use the verb **identify**, not "fix"
- Evaluate = strengths + limits + judgement

Common traps & misconceptions

Exam trap

□ The line examiners test If you only remember one thing: **authorisation is what makes hacking "ethical."** Take the permission away and the exact same activity becomes *unauthorised access* — a criminal offence. Many marks are won or lost on whether you mention permission / consent / authorisation.

Exam trap

△ Grey ≠ ethical A grey hat who finds a flaw and "does the right thing" by reporting it is **still breaking the law** — they had no authorisation. Don't write that grey-hat hacking is a type of ethical hacking. Only the white hat is ethical, because only the white hat was given permission first.

Exam trap

□ Phase 1 is the legal phase "Scope & authorise" isn't paperwork to skip — it's the **only** thing standing between a legal pen test and a crime. The signed agreement (often called *rules of engagement*) states exactly which systems can be tested, when, and how far. Step outside the scope and the white hat instantly becomes a black hat in the eyes of the law.

Exam trap

□ Trap 1 · "Hacking = bad" Writing that all hacking is illegal. Ethical hacking is **legal and valuable**. Define it by *authorisation and intent*, not by the word "hack."

Exam trap

□ Trap 2 · Forgetting permission Describing what a pen tester *does* without saying it's **authorised**. Without that word, you've described a criminal. Always state consent/permission/scope.

Exam trap

□ Trap 3 · "It fixes the network" Ethical hacking **identifies** vulnerabilities — it doesn't repair them. The organisation must then act (remediation). Match the study design's verb: *identify*.

Exam trap

□ Trap 4 · Grey = ethical Calling grey-hat hacking ethical. Reporting a flaw doesn't undo accessing a system you had no right to. Only the **white hat** is ethical.

Exam trap

❑ Trap 5 · One-and-done Treating a single pen test as permanent protection. It's a **snapshot in time**; networks change, so testing must be repeated.

Exam trap

❑ Trap 6 · Vague "they test stuff" "Evaluate" answers need **both sides** — concrete strengths (proactive, controlled, finds real holes) *and* limits (snapshot, doesn't fix, scope-bound) — then a judgement.

How to answer exam questions

Read the **command word** first — it sets how much to write. *State/Identify* wants a word or phrase; *Describe* wants features; *Explain* wants reasons and links; *Justify/Evaluate* wants a judgement backed by evidence. Always pull in the **scenario detail** rather than answering in the abstract. The examples below contrast a weak response with a strong one for the same question.

Q1. Define · 2 marks

The term *ethical hacking*.

✗ A weak answer

— 0-1 / 2 "Ethical hacking is when someone hacks into a computer to test it and find problems." Why it loses marks: no mention of *authorisation/permission* (the defining feature) and no mention of the *purpose* (identifying vulnerabilities). It describes any hacker.

✓ A strong answer

— 2 / 2 "Ethical hacking is the **authorised**, legal attempt to penetrate a network or system on behalf of its owner, in order to **identify vulnerabilities and weaknesses** so they can be fixed before a malicious attacker exploits them."

How the marks are awarded

- Marking guide · 2 marks 1 mark — authorised / with the owner's permission (legal).
- 1 mark — purpose is to identify vulnerabilities/weaknesses (so they can be fixed / before attackers exploit them). A definition missing the word "authorised" caps at 1 mark, however well-written.

X A weak answer

— 1 / 3 "Because they are a grey hat, not a white hat. Grey hats are in between so it's not really ethical." Why it loses marks: circular — it labels the hat instead of *explaining*. No reference to authorisation, and no link to the act being illegal.

X A weak answer

— 1 / 3 "Because they are a grey hat, not a white hat. Grey hats are in between so it's not really ethical." Why it loses marks: circular — it labels the hat instead of *explaining*. No reference to authorisation, and no link to the act being illegal.

✓ **A strong answer**
— 3 / 3 "Ethical hacking requires the owner's **prior authorisation** and an agreed scope. The grey hat accessed Clutch's system **without permission**, which means the access itself was **unauthorised — a criminal offence** — regardless of their good intent. Warning Clutch afterwards is responsible, but it doesn't retrospectively make the access legal, so it can't be classed as ethical hacking."

✓ **A strong answer**
— 3 / 3 "Ethical hacking requires the owner's **prior authorisation** and an agreed scope. The grey hat accessed Clutch's system **without permission**, which means the access itself was **unauthorised — a criminal offence** — regardless of their good intent. Warning Clutch afterwards is responsible, but it doesn't retrospectively make the access legal, so it can't be classed as ethical hacking."

How the marks are awarded

- Marking guide · 3 marks 1 mark — ethical hacking requires prior authorisation/permission (and scope).
- 1 mark — the grey hat had no permission, so the access was unauthorised / illegal.
- 1 mark — good intent (reporting it) doesn't change that it was unauthorised.

- ### How the marks are awarded
- Marking guide · 3 marks 1 mark — ethical hacking requires prior authorisation/permission (and scope).
 - 1 mark — the grey hat had no permission, so the access was unauthorised / illegal.
 - 1 mark — good intent (reporting it) doesn't change that it was unauthorised.

Q3. Describe · 4 marks

Clutch is launching a new feature in four weeks. Describe how commissioning an ethical hacking engagement could help Clutch identify vulnerabilities and weaknesses in its network before launch.

✗ A weak answer

— 1-2 / 4 "Ethical hackers would hack Clutch and find the problems and then Clutch would be safe. This is good because hackers can't get in anymore." Why it loses marks: no detail on *how* (no scanning, no specific weaknesses), overstates the outcome ("safe", "can't get in"), and ignores that Clutch must still fix what's found.

✓ A strong answer

— 4 / 4 "With Clutch's written permission and an agreed scope, a penetration tester would use the same techniques as a real attacker — scanning the network and probing the web server, app server, database and staff laptops — to **find weaknesses proactively**. They might uncover an open firewall port, unpatched server software, or a weak staff password. Because this happens **before launch and in a controlled way**, the tester reports each vulnerability to Clutch, who can then **patch them** — closing the holes on their own terms rather than after a real breach exposes 40,000 users' data."

How the marks are awarded

- Marking guide · 4 marks 1 mark — authorised tester uses real attacker techniques (scanning/probing the network).
- 1 mark — identifies specific weaknesses (e.g. open port, unpatched software, weak password).
- 1 mark — done proactively/in a controlled way before launch.
- 1 mark — findings reported so Clutch can fix/patch them (avoiding a breach).

Q4. Justify · 5 marks

Clutch's founders disagree. One says "we should just buy a better firewall instead of paying hackers." Justify the use of an ethical hacking engagement as part of Clutch's security, compared with relying on defensive tools alone.

✗ A weak answer

— 2 / 5 "They should do ethical hacking because it's better than a firewall and finds hackers. A firewall only blocks some things. Ethical hacking is more modern so Clutch should use it." Why it loses marks: asserts "better" without reasons or evidence, misunderstands a firewall, and never explains the unique value (proactive testing of real weaknesses). No genuine justification.

✓ A strong answer

— 5 / 5 "A firewall and other tools are **defensive** — they try to block attacks, but you can't be sure they're configured correctly or that they cover every gap. An ethical hacking engagement is **proactive and tests the whole system the way a real attacker would**, including the firewall itself, the servers, weak passwords and even staff behaviour — revealing weaknesses the tools quietly miss, such as a port the firewall was never set to block." "Critically, it finds these **before** a criminal does, in a controlled test Clutch can schedule, so Clutch fixes problems on its own terms rather than after a breach triggers Notifiable Data Breach obligations. This is why ethical hacking should be used **alongside** defensive tools, not instead of them: the firewall blocks, and the pen test verifies that the blocking — and everything else — actually works."

How the marks are awarded

- Marking guide · 5 marks (1 each, capped) Defensive tools are passive/can be misconfigured or incomplete. Ethical hacking is proactive and tests the whole network like a real attacker. It finds weaknesses tools miss (incl. config errors, passwords, people). Finds them before a real attack controlled, avoids breach consequences. Reasoned position: use it alongside tools, not instead of them.